附錄四、身分核驗安全設計及信賴等級評估彙總表

安全設計		身分登錄/信物管理	信賴等級
一、憑證簽章	FXML 硬體憑證	身分登錄 Level 5	最高 LoA5
		信物管理 Level 5	
	硬體自然人憑證	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	工商憑證 IC 卡(正卡)	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	法人高風險憑證－安全載具(如動態密碼產生器)	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	法人高風險憑證－具密碼保護之安全元件(SE)	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	法人高風險憑證－可信賴執行環境(TEE)	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	法人高風險憑證－行動裝置應用程式	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	C3 軟體憑證	身分登錄 Level 3、Level 2(數存三②)、Level 1(數存三①)	最低 LoA1(數存三①)、低 LoA2(數存三②)、

安全設計		身分登錄/信物管理	信賴等級
		信物管理 Level 3	中 LoA3
	FXML 軟體憑證	身分登錄 Level 5	中 LoA3
		信物管理 Level 3	
二、晶片金融卡	法人晶片金融卡	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	臨櫃晶片金融卡	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	數存一高風險	身分登錄 Level 4	高 LoA4
		信物管理 Level 4	
	數存一低風險	身分登錄 Level 3	中 LoA3
		信物管理 Level 4	
	數存二	身分登錄 Level 3	中 LoA3
		信物管理 Level 4	
	數存三①(連結本人之金融支付工具或電信認證)	身分登錄 Level 1	最低 LoA1
		信物管理 Level 4	
	數存三②(跨行金融帳戶資訊核驗)	身分登錄 Level 2	低 LoA2
		信物管理 Level 4	

安全設計		身分登錄/信物管理	信賴等級
	數存三③(跨行金融帳戶資訊核驗+視訊)	身分登錄 Level 3	中 LoA3
		信物管理 Level 4	
三、一次性密碼	法人高風險 OTP－安全載具(如動態密碼產生器)	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	法人高風險 OTP－具密碼保護之安全元件(SE)	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	法人高風險 OTP－可信賴執行環境(TEE)	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	法人高風險 OTP－行動裝置應用程式	身分登錄 Level 5	高 LoA4
		信物管理 Level 4	
	簡訊或軟體 OTP	身分登錄 Level 5(臨櫃)、Level 4(數存一高)、Level 3(數存一低、數存二)	低 LoA2
		信物管理 Level 2	
	簡訊或軟體 OTP（線上辦理貸款之純貸戶）	身分登錄 Level 1	最低 LoA1
		信物管理 Level 2	
		身分登錄 Level 1	最低

安全設計		身分登錄/信物管理	信賴等級
	簡訊或軟體 OTP（數存三①）	信物管理 Level 2	LoA1
	簡訊或軟體 OTP（數存三②）	身分登錄 Level 2	低 LoA2
		信物管理 Level 2	
	簡訊或軟體 OTP（數存三③）	身分登錄 Level 3	低 LoA2
		信物管理 Level 2	
	簡訊或軟體 OTP（信用卡）	身分登錄 Level 1	最低 LoA1
		信物管理 Level 2	
	語音或推播 OTP	身分登錄 Level 5(臨櫃)、Level 4(數存一高)、Level 3(數存一低、數存二)	中 LoA3
		信物管理 Level 3	
	語音或推播 OTP（數存三①）	身分登錄 Level 1	最低 LoA1
		信物管理 Level 3	
	語音或推播 OTP（數存三②）	身分登錄 Level 2	低 LoA2
		信物管理 Level 3	
	語音或推播 OTP（數存三③）	身分登錄 Level 3	中 LoA3
		信物管理 Level 3	

安全設計		身分登錄/信物管理	信賴等級
	語音或推播 OTP（信用卡）	身分登錄 Level 1	最低 LoA1
		信物管理 Level 3	
四、兩項以上技術	臨櫃或 VTM 辦理、法人、數存一高風險帳戶	身分登錄 Level 5(臨櫃或 VTM 辦理、法人)、Level 4(數存一高)	高 LoA4
		信物管理 Level 4	
	臨櫃或 VTM 辦理、法人、數存一高風險、數存一低、數存二、數存三③帳戶	身分登錄 Level 5(臨櫃或 VTM 辦理、法人)、Level 4(數存一高）、Level 3(數存一低、數存二、數存三③)	中 LoA3
		信物管理 Level 3	
	數存三②帳戶	身分登錄 Level 2	低 LoA2
		信物管理 Level 3	
	數存三①帳戶、信用卡戶	身分登錄 Level 1	最低 LoA1
		信物管理 Level 3	
五、視訊會議	VTM	身分登錄 Level 5	高 LoA4
		信物管理 Level 4 <u>額外控管要求</u>	
	手機或平板裝置	身分登錄 Level 3	中 LoA3
		信物管理 Level 3 <u>額外控管要求</u>	
六、知識詢問	知識詢問	身分登錄	最低

安全設計		身分登錄/信物管理	信賴等級
		Level 5(臨櫃)、Level 4(數存一高)、Level 3(數存一低、數存二、數存三③)、Level 2(數存三②)、Level 1(數存三①、信用卡)	LoA1
		信物管理 Level 1	
七、固定密碼	固定密碼	身分登錄 Level 5(臨櫃)、Level 4(數存一高)、Level 3(數存一低、數存二、數存三③) 、Level 2(數存三②)、Level 1(數存三①)	最低 LoA1
		信物管理 Level 1	
八、存款帳戶資訊	存款帳戶資訊	身分登錄 Level 5(臨櫃)、Level 4(數存一高)、Level 3(數存一低、數存二、數存三③) 、Level 2(數存三②) 、Level 1(數存三①)	最低 LoA1(數存三①)、 低 LoA2
		信物管理 Level 2	
九、信用卡資訊	信用卡資訊	身分登錄 Level 1	最低 LoA1
		信物管理 Level 1	
十、電信認證	經銀行核驗之電信認證	身分登錄 Level 5(臨櫃)、Level 4(數存一高)、Level 3(數存一低、數存二、數存三③) 、Level 2(數存三②)	低 LoA2

<table>
<tr><th colspan="2">安全設計</th><th>身分登錄/信物管理</th><th>信賴等級</th></tr>
<tr><td rowspan="3"></td><td></td><td>信物管理 Level 2</td><td></td></tr>
<tr><td rowspan="2">電信認證</td><td>身分登錄 Level 1</td><td rowspan="2">最低
LoA1</td></tr>
<tr><td>信物管理 Level 2</td></tr>
<tr><td rowspan="2">十一、金融 Fast ID</td><td rowspan="2">金融 Fast ID</td><td>身分登錄
Level 5(臨櫃)、Level 4(硬體自然人憑證、臨櫃申請開戶之晶片金融卡、數一高晶片金融卡)</td><td rowspan="2">中
LoA3</td></tr>
<tr><td>信物管理 Level 3</td></tr>
<tr><td rowspan="2">十二、行動自然人憑證</td><td rowspan="2">行動自然人憑證</td><td>身分登錄 Level 3</td><td rowspan="2">低
LoA2</td></tr>
<tr><td>信物管理 Level 2</td></tr>
</table>

附錄五、身分驗證階段常見安全設計要求

一、憑證簽章

身分驗證階段	（一）應確認憑證之合法性、正確性、有效性、保證等級及用途限制。 （二）應簽署適當內容；於簽入作業時，應簽署足以識別該個人之資料(如：個人統一編號)、於書面同意時，應簽署依相關法令規定之指定書件；應用於交易指示時，應簽署完整付款指示。

二、晶片金融卡

身分驗證階段	（一）應由原發卡行依據交易類型核驗對應之交易驗證碼(如：簽入得採餘額查詢交易) （二）系統應依每筆交易動態產製不可預知之端末設備查核碼，並檢核網頁回傳資料之正確性與有效性。 （三）於帳務性交易時，系統應每次輸入卡片密碼產生交易驗證碼。 （四）元件於存取卡片時應設計防止第三者存取。 （五）應提示收回卡片妥善保管。

三、一次性密碼

身分驗證階段	（一）應運用一次性密碼技術產生並限制一次性使用。 （二）所產生之一次性密碼，如應用於低風險非約定轉帳交易時，且該密碼與交易內容無關者，應限定該密碼於產生時起 120 秒內有效。應用於 ATM 無卡提款產生之一次性「提款序號」，其有效時限可由個別金融機構考量風險承擔之能力與客戶便利性斟酌訂定與調整，惟應不逾該序號產生時起 30 分鐘。

四、兩項以上技術

身分驗證階段	應具有下列三項之任兩項以上技術。 （一）客戶與金融機構所約定之資訊，且無第三人知悉(如密碼、圖形鎖、手勢等)。 （二）客戶所持有之設備，金融機構應確認該設備為客戶與金融機構所約定持有之實體設備(如密碼產生器、密碼卡、晶片卡、電腦、行動裝置、憑證載具、SIM 卡認證、晶片護照、金鑰等)。 （三）客戶提供給金融機構其所擁有之生物特徵，金融機構應直接或間接驗證該生物特徵。間接驗證係指由客戶端設備(如行動裝置)驗證或委由第三方驗證，金融機構僅讀

	取驗證結果，必要時應增加驗證來源辨識。 1、採用直接驗證生物特徵技術者，應確認真人及本人辦理並符合「金融機構運用新興科技作業規範」有關生物特徵資料安全控管要求。又金融機構應依據其風險承擔能力調整生物特徵參數(如近似率、錯誤接受率、錯誤拒絕率)，以期有效識別客戶身分；若無法有效確認真人或本人時應加強其他安全設計，並應透過第三方依據 ISO/IEC30107 攻擊樣態逐一進行檢測，以確保感測器所擷取的生物特徵是客戶的真實生物特徵，而非經過變造或偽冒。 2、採用間接驗證生物特徵技術者，應事先評估客戶身分驗證機制之有效性，善盡告知客戶使用上之風險，並提供間接驗證機制關閉管道；若該機制出現偽冒風險時，應加強其他安全設計(如交易密碼驗證、設備指定、推播確認、遞延交易並可偵測阻擋、降低額度、OTP 綁交易、語音 OTP、SIM 卡認證、錄影存證、雙向簡訊並可辨識來源電話、採用非交易設備確認交易內容或依金融機構風險評估至少具相同安全強度之安全機制，並應留存評估紀錄及核決層級)。

五、視訊會議

身分驗證階段	(一) 應留存政府核發用於身分識別之證件(如國民身分證、居留證或護照等)影像檔並進行驗證；若客戶係本國籍未成年人，應增加核驗其法定代理人之上述證明文件。 (二) 應導入機制協助確認真人及本人，以防止透過科技預先錄製影片、製作面具、模擬影像或深度偽造(deepfake)等機制偽冒身分。 (三) 應由金融機構確認客戶指示內容與其意思表示。

六、知識詢問

身分驗證階段	應核驗客戶所知悉之靜態資訊(如國小就讀學校)或動態資訊(如前次繳款紀錄)。

七、固定密碼

身分驗證階段	(一) 應核驗與客戶所約定之密碼。 (二) 透過網際網路傳輸途徑並採用戶代號及固定密碼進行唯一驗證之簽入介面，其安全設計應具備之安全設計原則如下： (1)用戶代號之安全設計： 甲、不得使用客戶之顯性資料(如個人統一編號、手

	機號碼、電子郵件帳號、信用卡號、存款帳號等)作為唯一之識別，否則應另行增設使用者代號以資識別。 乙、不應少於六位。 丙、不應訂為相同之英數字、連續英文字或連號數字。 丁、同一用戶代號在同一時間內僅能登入一個連線(session)控制之系統。 戊、如增設使用者代號，至少應依下列方式辦理： (甲)不得為金融機構已知之客戶顯性資料。 (乙)如輸入錯誤達五次，金融機構應做妥善處理。 (丙)新建立時不得相同於用戶代號及密碼；變更時，亦同。 (丁)變更時得核驗原使用者代號後辦理且不得與原使用者代號相同。 (2)固定密碼之安全設計： 甲、不應少於六位，若搭配交易密碼使用則不應少於四位且交易密碼應符合本目相關規定。 乙、建議採英數字混合使用，且宜包含大小寫英文字母或符號。 丙、不應訂為相同之英數字、連續英文字或連號數字，系統預設密碼不在此限。 丁、不應與用戶代號、使用者代號、交易密碼相同。 戊、密碼連續錯誤達五次，不得再繼續執行交易。 己、變更時得核驗原密碼後辦理且不得與原密碼相同。 庚、首次登入時，應強制變更系統預設密碼；若未於 30 日內變更者，則不得再以該密碼執行簽入。 辛、密碼超過一年未變更，金融機構應做妥善處理。 (3)採用圖形鎖或手勢之安全設計： 甲、連續錯誤達五次，不得再繼續執行交易。 乙、變更不得與原設定相同。 (三)透過公眾交換電話網路傳輸途徑並採用戶代號及固定密碼進行唯一驗證之簽入介面，其固定密碼之安全設計，應遵循前子目身分驗證相關要求，惟密碼長度不應少於四位。

八、存款帳戶資訊

身分驗證階段	(一)確認申請人與該帳戶持有人為同一統一編號且係透過臨櫃方式開立，以確認該帳戶之有效性。 (二)驗證他行存款帳戶有效性時,應採用符合財金公司之「跨行金融帳戶資訊核驗」機制辦理，以有卡方式核驗者應驗證晶片金融卡交易驗證碼,以無卡方式核驗者應發送簡訊或推播驗證一次性密碼。

九、信用卡

身分驗證階段	(一) 確認申請人與信用卡持卡人為同一個人統一編號且係透過信用卡授權交易方式，以確認該卡片之有效性(如預授權)。 (二) 驗證他行信用卡有效性時，應透過聯合信用卡處理中心及財金公司之「信用卡輔助持卡人身分驗證平臺」辦理。

十、電信認證

身分驗證階段	確認申請人與該門號租用人為同一個人統一編號且係透過用戶身分模組（Subscriber Identity Module，SIM）連線至該電信業者，確認該 SIM 之有效性。

十一、經銀行核驗之電信認證

身分驗證階段	確認申請人與該門號租用人為同一個人統一編號、該門號經銀行註冊,且透過用戶身分模組(Subscriber Identity Module, SIM）連線至該電信業者，確認該SIM之有效性。